

## SGSI-REG-005 — Registro de Requisitos Legales, Regulatorios y Contractuales

Organización: Atalaya Gestión Patrimonial SL

Versión: 1.4 | Estado: Vigente | Emisión v1.0: 10/06/2026 | Revisiones v1.1 a v1.4: 24/07/2026 | Aprobación v1.4: Comité de Seguridad Convergente, 24/07/2026 (acta del Comité de 24/07/2026), conforme a SGSI-DOC-002 §4 | Clasificación: Interna | Propietario: Dirección General — Atalaya GP SL | Autor: El consultor (externo)

Objeto: identificar los requisitos legales, regulatorios y contractuales con efecto sobre la seguridad de la información en el alcance del SGSI (cláusula A 5.31 y SGSI-DOC-001 §4), su traducción práctica para Atalaya y el documento del sistema que los desarrolla.

Criterio: se registran también los marcos evaluados y descartados (con justificación), para dejar constancia de que la exclusión es una decisión y no un olvido.

Revisión: anual, y ante cambio normativo, de jurisdicción o de estructura patrimonial. La asesoría legal externa (España e Irlanda) valida el contenido en cada revisión.

*Cambios v1.1: alta de L-09 (limitación y declaración de pagos en efectivo, derivado de RSC-019), L-10 (coordinación de actividades empresariales con contratas, derivado de RSC-020) y L-11 (tratamiento de datos de los registros de acceso y visitas, derivado de RSC-020 y RSC-021).*

*Vocabulario de la columna «Estado» (valores exactos): Cumple | En implantación | No aplicable | Aplicable a futuro. Se cierra el vocabulario en la v1.2 y se reordenan las entradas por bloque (L legales, C contractuales, N evaluados no aplicables, F aplicables a futuro), que en la v1.1 quedaron al final por orden de alta.*

*Cambios v1.2: corrección de la referencia de retención de L-11 a SGSI-DOC-002 §5.1 (la §7 no existe); cierre del vocabulario de la columna «Estado», con L-11 pasando de «Pendiente» a «En implantación»; y reordenación de las entradas por bloque. Sin altas ni bajas de requisitos.*

*Cambios v1.3: corrección del alcance de la reactivación de controles citada en F-01, que declaraba «8.25 a 8.30» cuando los diez controles no aplicables de SGSI-REG-003 se excluyen por la misma causa y los diez se reactivan al entrar en alcance la herramienta de IA (SGSI-REG-003, Portada). Sin altas ni bajas de requisitos.*

*Cambios v1.4: alta del campo Autor y del pie de control documental exigidos por SGSI-DOC-002 §2, retirada del sufijo*

*«— aprobado» del campo Estado, ajeno al vocabulario de SGSI-DOC-002 §3, y constancia expresa del órgano que aprueba este*

*registro, que SGSI-DOC-002 §4 designa como uno de los que requieren aprobación formal del Comité. Sin altas, bajas ni cambios en los requisitos registrados ni en su estado.*

| ID   | Ámbito              | Requisito / norma                                                                        | Jurisdicción | Obligaciones clave para Atalaya                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   | Documento SGSI que lo desarrolla                             | Propietario       | Estado          |
|------|---------------------|------------------------------------------------------------------------------------------|--------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------|-------------------|-----------------|
| L-01 | Protección de datos | RGPD (Reglamento UE 2016/679)                                                            | UE           | Base jurídica y minimización en todos los tratamientos; protección reforzada de datos de menores (tres en el alcance); derechos de los interesados, incluido el personal doméstico y de terceros; notificación de brechas a la AEPD en 72 h cuando proceda; registro de actividades de tratamiento. Evaluación de impacto (EIPD, art. 35) obligatoria antes de poner en marcha cualquier monitorización sistemática de personas: es requisito previo a la herramienta de vigilancia de huella digital prevista (Fase 2 del caso). | DOC-002 §5; DOC-009; registro de tratamientos (asesoría DPO) | Dirección General | En implantación |
| L-02 | Protección de datos | LOPDGDD 3/2018                                                                           | España       | Concreciones nacionales del RGPD; derechos digitales de los trabajadores (arts. 87-90): límites y transparencia en el control de dispositivos y en la videovigilancia laboral; información al personal doméstico y de contratas afectado por la CCTV.                                                                                                                                                                                                                                                                             | DOC-002 §5; DOC-006; norma de uso de dispositivos            | Dirección General | En implantación |
| L-03 | Videovigilancia     | RGPD/LOPDGDD + criterios AEPD sobre videovigilancia                                      | España       | Carteles informativos, plazo máximo de conservación de imágenes (30 días salvo incidente), acceso restringido y registrado a las grabaciones, ponderación en zonas de tránsito de personal. Afecta directamente a la CCTV de residencia y oficina.                                                                                                                                                                                                                                                                                | DOC-006 §5; PT-07; retención en DOC-002                      | Jefe de seguridad | En implantación |
| L-04 | Seguridad privada   | Ley 5/2014 de Seguridad Privada y reglamento                                             | España       | Los servicios de escolta y vigilancia solo pueden prestarlos empresas y personal habilitados; obligaciones de contrato y comunicación; límites a lo que el personal de seguridad puede hacer (p. ej., tratamiento de imágenes). Condiciona el contrato con la empresa de seguridad física.                                                                                                                                                                                                                                        | DOC-006 (anexo contractual T2)                               | Jefe de seguridad | Cumple          |
| L-05 | Mercantil           | Ley de Sociedades de Capital y obligaciones registrales                                  | España       | Deberes del órgano de administración, cuentas anuales, llevanza y conservación de documentación societaria. Define parte de la información Confidencial del alcance y sus plazos de conservación.                                                                                                                                                                                                                                                                                                                                 | DOC-002 §5-6; inventario de información                      | Dirección General | Cumple          |
| L-06 | Fiscal              | Obligaciones tributarias (LGT) incl. declaración de bienes en el extranjero (Modelo 720) | España       | La posición patrimonial exterior del principal es información fiscal obligatoria y de máxima sensibilidad; su preparación implica el flujo España ↔ Irlanda (RSC-006, RSC-007). Conservación de soporte documental en plazos legales.                                                                                                                                                                                                                                                                                             | DOC-007; canal cifrado con asesores (O2)                     | Resp. financiero  | Cumple          |

|      |                                                 |                                                                                                                                |          |                                                                                                                                                                                                                                                                                                                                   |                                                 |                   |                 |
|------|-------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------|----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------|-------------------|-----------------|
| L-07 | Societario y fiscal                             | Companies Act 2014 y obligaciones ante Revenue                                                                                 | Irlanda  | Obligaciones de las sociedades irlandesas del principal, gestionadas por asesores externos en Dublín. Para Atalaya: exactitud y protección de la información que remite, y verificación de las instrucciones que recibe de esa vía (RSC-005).                                                                                     | DOC-006 §4; DOC-007 R1/R4                       | Resp. financiero  | En implantación |
| L-08 | Blanqueo de capitales                           | Ley 10/2010 (PBC/FT) — efectos indirectos                                                                                      | España   | Atalaya no es sujeto obligado, pero banca, notarios y asesores sí: debe atender requerimientos KYC/diligencia debida con información veraz y por canales seguros, y prever que los cambios societarios disparan revisiones de las entidades.                                                                                      | DOC-007 §3 (contactos verificados)              | Resp. financiero  | Cumple          |
| L-09 | Medios de pago                                  | Ley 7/2012 y Ley 11/2021 (limitación de pagos en efectivo); Orden ETD/1217/2022 (declaración de movimientos de medios de pago) | España   | Límite legal a los pagos en efectivo en operaciones con empresarios o profesionales y obligación de declarar movimientos de medios de pago por encima de los umbrales establecidos (territorio nacional y entrada/salida del país). Afecta directamente a la práctica de disposición y entrega de efectivo en mano.               | DOC-007 §6 (regla E5); C-038, C-039 (PT-12)     | Resp. financiero  | En implantación |
| L-10 | Prevención de riesgos laborales                 | Ley 31/1995 y RD 171/2004 (coordinación de actividades empresariales)                                                          | España   | Obligación del titular del centro de trabajo de informar y coordinar con las empresas concurrentes, y deber de vigilancia sobre contratas y subcontratas. Aplica al acceso de obras, reparaciones y mantenimiento a la residencia y la oficina; refuerza, por vía legal, la exigencia de planificación y relación nominal previa. | DOC-006 §7 (reglas O1-O5); C-042, C-043 (PT-13) | Dirección General | En implantación |
| L-11 | Protección de datos — videovigilancia y accesos | RGPD/LOPDGDD art. 22 LOPDGDD; criterios AEPD sobre registros de acceso                                                         | España   | Los registros nominales de acceso de contratas y visitas y el registro de visitas de la sección 8 de DOC-006 constituyen tratamiento de datos personales: exigen base jurídica, información a los afectados, minimización y plazo de conservación definido.                                                                       | DOC-002 §5.1 (retención); DOC-006 §7 y §8       | Dirección General | En implantación |
| C-01 | Contractual                                     | Condiciones de banca privada (3 entidades)                                                                                     | ES/CH/IE | Obligaciones de custodia de credenciales y de comunicación de apoderamientos; aceptación escrita por las entidades de las reglas de verificación de Atalaya (la voz no verifica; confirmación de doble canal).                                                                                                                    | DOC-007 R2 y §3                                 | Resp. financiero  | En implantación |
| C-02 | Contractual                                     | Pólizas personales de la familia                                                                                               | ES/UE    | Deber de sigilo del tomador sobre la existencia y condiciones de las pólizas como condición de cobertura; requisitos del asegurador sobre medidas de protección. Información clasificada Restringida con acceso limitado a dos personas.                                                                                          | DOC-001 §6 (partes interesadas); DOC-002 §5     | Dirección General | Cumple          |

|      |                               |                                                      |           |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |                                                                          |                   |                    |
|------|-------------------------------|------------------------------------------------------|-----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------|-------------------|--------------------|
| C-03 | Contractual                   | Acuerdos de confidencialidad con asesores y terceros | ES/IE     | Obligaciones recíprocas de confidencialidad y de notificación de incidentes en <24 h; derecho de auditoría sobre T1. Su firma es condición previa al acceso (DOC-006 §6).                                                                                                                                                                                                                                                                                                                                                                           | DOC-006 §3, §6; ACU-001/002                                              | Dirección General | En implantación    |
| N-01 | Evaluado — no aplicable       | Directiva NIS2 / trasposición española               | UE/España | Atalaya no es entidad esencial ni importante de los sectores del anexo: fuera de ámbito subjetivo. Se registra la evaluación para evidenciar que la exclusión es deliberada. Revisar si cambia la actividad.                                                                                                                                                                                                                                                                                                                                        | —                                                                        | Dirección General | No aplicable       |
| N-02 | Evaluado — no aplicable       | Reglamento DORA                                      | UE        | Atalaya no es entidad financiera regulada; sus proveedores financieros sí están sujetos, lo que puede trasladarle requisitos vía contrato (se vigilará en C-01).                                                                                                                                                                                                                                                                                                                                                                                    | —                                                                        | Dirección General | No aplicable       |
| F-01 | Evaluado — aplicable a futuro | Reglamento (UE) 2024/1689 de Inteligencia Artificial | UE        | Hoy sin sistemas de IA en operación: sin obligaciones activas. Será de aplicación cuando entre en alcance la herramienta de monitorización de huella digital de la familia (Fase 2): clasificación de riesgo del sistema, gobernanza de datos, transparencia y supervisión humana. Su cumplimiento se gestionará mediante un sistema de gestión de IA conforme a ISO/IEC 42001, integrado con este SGSI; los diez controles hoy excluidos de la SoA (8.4, 8.11, 8.25 a 8.31 y 8.33) se reactivarán en ese momento, como la propia SoA deja escrito. | SoA (los diez controles no aplicables, reactivables); EIPD previa (L-01) | Dirección General | Aplicable a futuro |